

QuantumShield — Week 2 Report

Date: 2026-09-20

Tracks: Person A (Research & Design) + Person B (Build)

Status: Person A artefacts complete; awaiting Person B scanner output for final evidence merge.

1. Tasks Completed (Person A)

#	Deliverable	Location	Status
1	Requirements & Scope Document	<code>docs/week2-scope.md</code>	Done
2	CBOM Field Reference (spec for <code>cbom_writer.py</code>)	<code>docs/cbom-field-reference.md</code>	Done
3	Tool Evaluation / Comparison Table	<code>docs/tool-comparison.md</code>	Done (research); “real gaps” row pending Person B runs
4	Risk Scoring Formula Draft	<code>docs/qri-formula-draft.md</code>	Done
5	Architecture description + README	<code>docs/architecture.md</code> , <code>root README.md</code>	Done
6	This report skeleton	<code>docs/week2-report.md</code>	Done

Key Design Decisions Locked

- Scanner defaults every relationship to `uses` (application code calling crypto).
- Primary output format: CycloneDX 1.6+ with `type: "cryptographic-asset"` and `evidence.occurrences`.
- Quantum Factor tiers: 1.5 (Shor), 1.2 (Grover), 1.0 (quantum-safe).

- Confidence is multiplied into the risk score from day one.

Research Sources Used

- IBM CBOM (original) → upstreamed into CycloneDX 1.6/1.7
 - OWASP CycloneDX Authoritative Guide to CBOM
 - cdxgen, sonar-cryptography, cbomkit-theia public documentation
 - Ishchukova et al. QRI formulation (CVSS × Quantum Factor × HNDL term)
-

2. Roadblocks / Open Items

- Person B has not yet returned actual `cbom.json` output from cdxgen / sonar-cryptography runs → “Real observed gaps” section in `tool-comparison.md` is still a placeholder.
 - No sample-repo CBOM from our own scanner yet → final validation numbers cannot be written.
 - Diagram is currently textual; a draw.io / Excalidraw PNG can be dropped into `docs/architecture.png` when convenient.
-

3. Next Week Plan

Owner	Task
Person B	Land working <code>scanner.py</code> + <code>cbom_writer.py</code> , commit sample <code>cbom.json</code> , fill real gaps in tool-comparison
Person A	Merge Person B’s evidence into this report, finalise justification paragraph, prepare Week-3 scoring engine kick-off
Joint	Validate generated CBOM with ajv / cdx-validate, confirm Definition of Done is met

Appendix — Definition of Done (recalled)

Scanner detects RSA/ECDSA/DH/AES/MD5 usage in a sample Python and/or Java repository and outputs a schema-valid `cbom.json`.

Once Person B hands over the working artefacts, this report will be updated with concrete evidence and marked complete.